



DOCUMENTAZIONE TECNICA

Whitepaper Sicurezza e Conformità

Formicanera Agent Management System — Architettura, misure di protezione dei dati, documentazione di conformità GDPR e NIS2 indirizzata ai team IT e Legale/Compliance di Gebr. Brasseler GmbH & Co. KG.

- Principio di Non-Interferenza con l'ERP Komet — metodologia RPA illustrata
- Misure di sicurezza tecnica: MFA, AES-256-GCM, audit trail immutabile, RBAC
- Conformità GDPR: ruoli, basi giuridiche, implementazione dei diritti degli interessati
- Mappatura dei controlli NIS2 (Direttiva 2022/2555) — conformità all'Art. 21

1. Contesto Contrattuale e Ruoli GDPR

Prima di affrontare le misure tecniche, è essenziale definire il quadro giuridico che disciplina tutti i trattamenti di dati personali effettuati da Formicanera — e i ruoli precisi di ciascuna parte ai sensi del GDPR.

Gebr. Brasseler GmbH & Co. KG / Komet Italia S.r.l. — Titolare del Trattamento

Ai sensi dell'**Art. 4(7) GDPR**, Komet Italia S.r.l. determina le finalità e i mezzi del trattamento dei dati personali degli agenti e dei clienti nell'ambito della rete commerciale Komet. Gebr. Brasseler, in qualità di società capogruppo, esercita la vigilanza sulle pratiche di conformità delle entità del gruppo Komet.

Formicanera — Responsabile del Trattamento

Ai sensi dell'**Art. 28 GDPR**, Formicanera tratta dati personali esclusivamente per conto di Komet Italia S.r.l. e in conformità alle istruzioni documentate da quest'ultima. Si tratta dello stesso modello standard adottato da Salesforce, Microsoft 365, Google Workspace e da ogni grande fornitore SaaS enterprise operante in Europa.

Elementi Strutturali Fondamentali

- ✓ Un **Accordo per il Trattamento dei Dati (DPA ex Art. 28 GDPR)** pienamente conforme al Regolamento sarà formalmente sottoscritto prima dell'avvio del sistema — esattamente come previsto dal Regolamento e come prassi consolidata nell'intero settore SaaS.
- ✓ Le credenziali ERP dell'agente commerciale sono **assegnate da Komet Italia S.r.l.** — tutte le operazioni automatizzate eseguite da Formicanera rimangono rigorosamente entro il perimetro di autorizzazione dell'agente come definito da Komet Italia.
- ✓ Formicanera non tratta **alcun dato al di fuori del perimetro del rapporto di agenzia** . I dati dei clienti, lo storico ordini e i documenti contabili sono trattati esclusivamente per l'esecuzione delle attività commerciali contrattuali dell'agente.
- ✓ Tutti i dati rimangono in ogni momento all'interno dell'**Unione Europea** . Non vengono effettuati trasferimenti internazionali al di fuori del quadro delle Clausole Contrattuali Standard dell'UE.
- ✓ L' **ERP Komet rimane il registro autoritativo** di tutte le transazioni. Formicanera non costituisce un'autorità parallela sui dati — sincronizza una vista ottimizzata per la consultazione sul campo.

Contesto di settore: Il modello Titolare/Responsabile del Trattamento non è una costruzione giuridica esclusiva di Formicanera — è l'architettura standard alla base di ogni deployment SaaS B2B in Europa. Salesforce, SAP e Microsoft operano nell'ambito di identici framework GDPR quando trattano dati per conto dei propri clienti enterprise. Ciò che distingue Formicanera è il perimetro di trattamento ristretto e ben definito: i dati commerciali di un singolo agente, mai aggregati tra agenti, mai condivisi con terze parti al di fuori dell'elenco documentato dei sub-responsabili del trattamento.

2. Il Principio di Non-Interferenza con l'ERP Komet

Questa è la sezione operativamente più significativa del presente documento. La questione dell'integrità dell'ERP è al centro di qualsiasi revisione IT responsabile e merita una risposta precisa e verificabile.

Cosa Fa Concretamente Formicanera

Formicanera non aggira l'ERP. Automatizza esattamente ciò che l'agente già compie manualmente.

In concreto: un browser Chromium standard si autentica nell'ERP Komet Archibald utilizzando **le credenziali personali d'agente del Sig. Formicola** — le stesse credenziali assegnate da Komet Italia per la sua attività commerciale. Il sistema naviga quindi le stesse schermate dell'interfaccia che l'agente navigherebbe manualmente, leggendo dati di ordini, anagrafiche clienti e documenti ufficiali quali fatture e documenti di trasporto. Quando l'agente invia un ordine tramite la PWA Formicanera, il browser compila il modulo d'ordine nell'ERP usando le stesse credenziali e lo invia attraverso l'interfaccia ERP standard.

Nessun permesso elevato

Il sistema utilizza esclusivamente il ruolo agente standard all'interno dell'ERP. Non dispone di accesso amministrativo, non accede a schermate di configurazione e non ha possibilità di modificare le impostazioni dell'ERP né di accedere ai dati di altri agenti.

Nessuna credenziale condivisa

Le credenziali ERP di ciascun agente sono utilizzate esclusivamente dalla sessione automatizzata di quell'agente. Non esiste un insieme di credenziali condiviso o in pool. L'accesso incrociato tra agenti è architetturalmente impossibile.

Nessun dato al di fuori del perimetro autorizzato

Il sistema vede esattamente ciò che vede l'agente — non un byte in più. Non può accedere a territori, clienti o documenti che l'agente non possa accedere manualmente attraverso l'interfaccia ERP standard.

L'ERP come registro della verità

Tutti gli ordini inviati confluiscono nell'ERP Komet come sistema autoritativo. Formicanera non crea un registro parallelo delle transazioni — fornisce un'interfaccia mobile ottimizzata per la lettura sui dati propri dell'ERP.

Di Cosa Si Tratta — e di Cosa Non Si Tratta

Si tratta di **RPA — Robotic Process Automation**: una tecnica standard di settore utilizzata da imprese di tutto il mondo, equivalente per natura a un utente che opera il software tramite scorciatoie da tastiera, script o strumenti di accessibilità. L'RPA è esplicitamente riconosciuta dai principali framework di settore (ISO/IEC, ENISA) come tecnica di automazione legittima che opera interamente entro i limiti dell'autorizzazione utente esistente.

Ciò non configura accesso informatico non autorizzato ai sensi della Direttiva 2013/40/UE relativa agli attacchi contro i sistemi informatici, né ai sensi del §202a StGB (Codice Penale tedesco sull'accesso non autorizzato ai dati). L'autorizzazione di accesso sottostante — le credenziali d'agente del Sig. Formicola e il suo diritto contrattuale di utilizzo dell'ERP Komet, concesso da Komet Italia S.r.l. — è valida, attuale e formalmente documentata nel contratto di agenzia datato 1° gennaio 2026.

"Pensate a Formicanera come a una versione esperta e disciplinata dell'agente stesso — una versione che accede all'ERP a intervalli prevedibili, non dimentica mai di effettuare il logout e genera **un carico**

non superiore a quello di un umano al lavoro alla propria scrivania. Non introduce nuovi accessi; rende l'accesso esistente e autorizzato più coerente e affidabile."

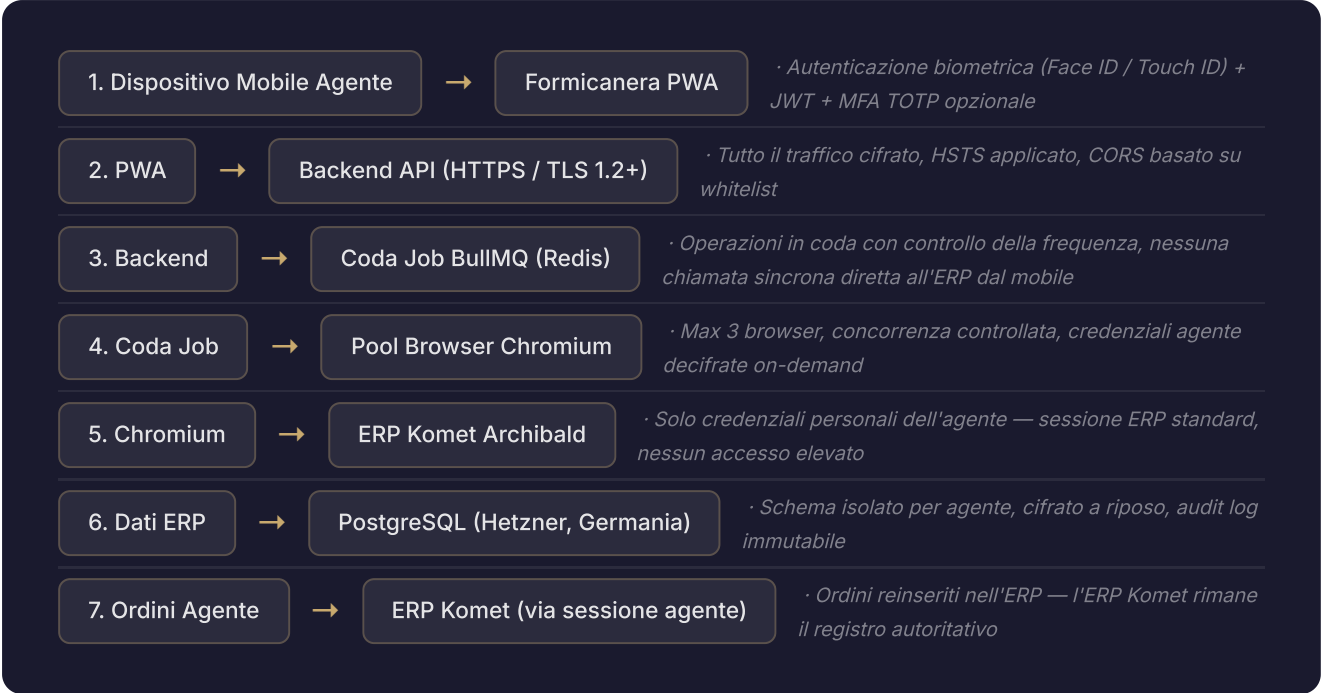
Carico sull'ERP e Protezione delle Prestazioni

- ✓ **Meno erratico di un utente umano:** le interazioni automatizzate sono distanziate da intervalli obbligatori, impedendo qualsiasi picco di richieste che un agente impegnato potrebbe inavvertitamente generare.
- ✓ **Sospensione automatica in caso di indisponibilità dell'ERP:** se l'ERP non risponde, è in manutenzione o presenta anomalie, il sistema lo rileva immediatamente e sospende ogni interazione senza cicli aggressivi di ritentativi.
- ✓ **Sincronizzazione consapevole dell'attività:** quando l'agente è inattivo (serate, fine settimana), la frequenza di sincronizzazione si riduce automaticamente, diminuendo ulteriormente l'interazione con l'ERP nelle ore di inattività.
- ✓ **Nessuna degradazione delle prestazioni ERP osservata:** durante l'intero periodo operativo, nessun impatto sulle prestazioni dell'ERP Komet attribuibile al sistema Formicanera è stato registrato.
- ✓ **Protezione dell'integrità dei dati:** se una interrogazione all'ERP restituisce risultati vuoti per qualsiasi motivo (incluse condizioni di rete transitorie), i dati locali esistenti vengono preservati — il sistema non sovrascrive mai record validi con risposte vuote.

3. Architettura del Flusso dei Dati

Di seguito è descritto il flusso dei dati end-to-end completo, dal dispositivo mobile dell'agente all'ERP Komet e ritorno, con tutti i controlli di sicurezza applicati ad ogni confine.

Flusso dei Dati — Passo per Passo



Proprietà Architettureali Fondamentali

Tutti i dati conservati in Germania (UE)

Il server di produzione è un VPS Hetzner CPX32 situato a Falkenstein, Germania. I backup su Object Storage utilizzano la region fsn1 di Hetzner (Francoforte, Germania). Nessun dato viene conservato al di fuori dell'Unione Europea.

Isolamento dei dati per agente

I dati di ciascun agente sono conservati in uno schema isolato. Non esiste uno strato di dati condiviso tra agenti — un bug, una configurazione errata o una sessione compromessa relativa a un agente non può esporre i dati di un altro agente.

Nessun percorso diretto mobile-ERP

Il dispositivo mobile dell'agente non comunica mai direttamente con l'ERP. Tutte le interazioni con l'ERP sono mediate attraverso il server backend, garantendo un confine di sicurezza netto e un audit trail completo.

L'ERP come fonte autoritativa

Gli ordini inviati dall'agente confluiscono nell'ERP Komet attraverso l'interfaccia di invio standard. Komet Italia mantiene piena autorità sull'accettazione o il rifiuto degli ordini, coerentemente con l'Art. 2(g) del contratto di agenzia.

4. Misure di Sicurezza Tecnica Implementate

Le seguenti misure di sicurezza sono attualmente implementate in produzione, operative dall'aprile 2026 e documentate nella Dichiarazione di Conformità Tecnica (n. 2026-001).

4.1 — Autenticazione e Gestione delle Sessioni

JWT con Revoca Attiva (blacklist Redis): Il sistema implementa token di accesso JWT con un identificatore crittograficamente univoco (jti, UUID v4) per token. Al logout, il jti viene inserito in un elenco di revoca Redis con TTL dinamico calcolato dalla scadenza del token. Il middleware di autenticazione verifica la revoca ad ogni richiesta. I token sottratti vengono invalidati nel momento in cui l'agente effettua il logout.

MFA TOTP (RFC 6238): L'autenticazione a più fattori è implementata tramite password monouso basate sul tempo. Il segreto TOTP è cifrato con AES-256-GCM prima della persistenza in database — non è mai accessibile in chiaro, non viene mai trasmesso nelle risposte API. Vengono forniti otto codici di recupero monouso, memorizzati con hash bcrypt. L'endpoint di configurazione MFA è soggetto a limitazione della frequenza delle richieste (rate limiting: 5 richieste / 15 minuti per IP).

Device Trust MFA (esenzione 30 giorni): Per ridurre l'attrito mantenendo la sicurezza, un token di dispositivo attendibile (hash SHA-256 memorizzato in database) consente di omettere l'OTP per un massimo di 30 giorni su un dispositivo verificato. La relazione di fiducia è specifica del dispositivo e revocabile dal pannello di amministrazione.

Autenticazione Biometrica (WebAuthn): La PWA integra Face ID e Touch ID tramite l'API WebAuthn nativa del sistema operativo. I dati biometrici sono elaborati esclusivamente dall'enclave sicura del dispositivo — non vengono mai trasmessi al server, mai memorizzati lato server e mai accessibili allo strato applicativo. Il server riceve esclusivamente un'attestazione crittografica del completamento con successo della verifica biometrica locale.

4.2 — Limitazione della Frequenza delle Richieste (Rate Limiting) su Tutti gli Endpoint Sensibili

Endpoint	Finestra	Limite	Risposta al Superamento
POST /api/auth/login	15 minuti	5 tentativi	HTTP 429 + registrazione audit log
POST /api/auth/refresh	60 minuti	20 richieste	HTTP 429
POST /api/auth/mfa-verify	15 minuti	10 tentativi	HTTP 429
POST /api/auth/mfa-setup	15 minuti	5 richieste	HTTP 429
POST /api/auth/mfa-confirm	15 minuti	5 richieste	HTTP 429

Ogni superamento della soglia di login viene registrato nell'audit log immutabile con IP dell'attore, user agent e timestamp.

4.3 — Cifratura

- ✓ **AES-256-GCM a riposo** per le credenziali ERP e i segreti MFA — lo stesso standard di cifratura utilizzato nelle applicazioni di servizi finanziari. La derivazione della chiave utilizza PBKDF2-HMAC-SHA256. La chiave di cifratura è conservata esclusivamente come variabile d'ambiente, mai nel codice sorgente, mai nei log, mai trasmessa in alcuna risposta API.

- ✓ **TLS 1.2+ in transito** per tutte le comunicazioni tra client mobile e server backend — gestito da Nginx con certificati Let's Encrypt rinnovati automaticamente. Non esiste alcun percorso dati non cifrato.
- ✓ **Applicazione HSTS** previene gli attacchi di downgrade del protocollo. Tutte le connessioni HTTPS sono imposte a livello di trasporto.
- ✓ **Nessun segreto nel codice sorgente** — tutte le chiavi crittografiche, le credenziali database e i token API sono gestiti come variabili d'ambiente nell'ambiente container di produzione.

4.4 — Controllo degli Accessi (RBAC)

Il sistema implementa quattro livelli di ruolo con permessi per modulo a livello utente:

Ruolo	Perimetro	MFA
admin	Accesso completo inclusi pannello admin, audit log, gestione utenti	Opzionale
office	Accesso operativo avanzato (fatture, DDT, storico completo)	Opzionale
agent	Accesso agente standard: propri clienti, propri ordini, prodotti	Opzionale
dealer	Accesso dealer: storico ordini Fresis e sottoinsieme clienti	Opzionale

Ogni utente dispone inoltre di un array di moduli per utente (`modules` JSONB) che limita l'accesso ad aree funzionali specifiche. L'assegnazione dei moduli è gestita esclusivamente dagli amministratori. Un amministratore non può accidentalmente bloccare se stesso (self-role guard).

4.5 — Header HTTP di Sicurezza

- ✓ **Strict-Transport-Security (HSTS)** con max-age elevato
- ✓ **Content-Security-Policy (CSP) restrittiva:** `default-src 'self'; script-src 'self'; style-src 'self' 'unsafe-inline'; img-src 'self' data;; connect-src 'self' wss;; object-src 'none'; frame-src 'none'`
- ✓ **X-Frame-Options: DENY** — previene gli attacchi di clickjacking
- ✓ **X-Content-Type-Options: nosniff** — previene il MIME-type sniffing
- ✓ **Whitelist CORS:** le richieste cross-origin sono accettate esclusivamente da `https://formicanera.com` — tutte le altre origini vengono respinte a livello middleware

4.6 — Audit Trail Immutabile

Il sistema mantiene un audit log persistente e append-only in `system.audit_log` (PostgreSQL). L'immutabilità a livello database è garantita da:

`REVOKE UPDATE, DELETE ON system.audit_log FROM archibal`d — l'utente database applicativo è strutturalmente impedito dal modificare o cancellare qualsiasi record di audit. La rimozione di record richiederebbe accesso superuser diretto con credenziali separate non utilizzate dall'applicazione.

Eventi tracciati nell'audit log:

- ✓ Tutti i tentativi di login (riusciti e falliti), logout, revoche di token
- ✓ Creazione, modifica, cancellazione di ordini (singoli e in batch)
- ✓ Operazioni di cancellazione GDPR (Art. 17) ed esportazione dati (Art. 20) — con ID attore e timestamp

- ✓ Operazioni di gestione utenti (assegnazione ruoli, modifiche moduli, configurazione MFA)
- ✓ Alert di sicurezza: login falliti ripetuti, attivazione circuit breaker, superamento rate limit, errori di sistema ad alta frequenza

4.7 — Gate di Sicurezza CI/CD

La pipeline di integrazione continua (GitHub Actions) esegue `npm audit --audit-level=critical` ad ogni push nel repository. Le vulnerabilità critiche bloccano sia la build sia il deployment automatico. Il software non può essere distribuito in produzione con vulnerabilità critiche note nelle proprie dipendenze.

5. Conformità GDPR

Formicanera tratta dati personali in qualità di Responsabile del Trattamento ai sensi dell'Art. 28 GDPR. Di seguito sono documentate le categorie di dati trattati, le basi giuridiche e l'implementazione dei diritti degli interessati.

5.1 — Categorie di Dati Personali Trattati

Dati degli agenti

Nome e cognome, credenziali di accesso (password con hash bcrypt), credenziali ERP cifrate, configurazione MFA (segreto TOTP cifrato), ruoli e moduli assegnati, log di attività (conservazione rolling 90 giorni). Nessun dato di categoria particolare ai sensi dell'Art. 9 GDPR.

Dati dei clienti

Ragione sociale, partita IVA, codice fiscale, sede legale, indirizzo e-mail, numeri di telefono, storico ordini, documenti fatture, documenti di trasporto. Tutti i dati hanno origine dall'ERP Komet — Formicanera non raccoglie dati dei clienti in modo indipendente.

Non vengono trattati dati sanitari, dati biometrici (lato server), dati genetici né alcun altro dato di categoria particolare ai sensi dell'Art. 9 GDPR. L'autenticazione biometrica (Face ID/Touch ID) è elaborata interamente sul dispositivo — nessun dato biometrico raggiunge il server.

5.2 — Basi Giuridiche del Trattamento

Attività di Trattamento	Base Giuridica	Articolo GDPR
Gestione ordini e operazioni sulla relazione con i clienti	Esecuzione di un contratto	Art. 6(1)(b)
Autenticazione, gestione sessioni, monitoraggio della sicurezza	Legittimo interesse (sicurezza informatica)	Art. 6(1)(f)
Validazione partita IVA	Obbligo legale (adempimento fiscale)	Art. 6(1)(c)
Conservazione audit log	Legittimo interesse + obbligo legale	Art. 6(1)(c)(f)

5.3 — Diritti degli Interessati — Implementazione

Diritto	Implementazione	Tempi di Risposta
Accesso (Art. 15)	Esportazione completa dei dati disponibile tramite pannello admin; audit log di tutte le operazioni ispezionabile	Entro 30 giorni
Cancellazione (Art. 17)	POST /api/admin/customers/:id/gdpr-erase — anonimizza 19 campi di dati personali nelle tabelle agents.customers e shared.sub_clients. Campi sostituiti con marker tracciabile [GDPR_ERASED_<timestamp ISO>]. I record strutturali (ordini, storico) sono conservati per obblighi fiscali, privati dei riferimenti identificativi. Operazione bloccata in presenza di ordini attivi. Ogni cancellazione registrata in audit log con ID attore.	Entro 30 giorni
Portabilità (Art. 20)	GET /api/admin/customers/:id/export — produce un archivio JSON strutturato contenente tutti i dati del cliente: profilo, ordini, articoli degli ordini, sub-clienti collegati. Restituito con Content-Disposition: attachment. Ogni esportazione registrata in audit log.	Entro 30 giorni
Rettifica (Art. 16)	Record clienti modificabili da ruoli admin/office autorizzati tramite interfaccia admin standard	Entro 30 giorni

Diritto	Implementazione	Tempi di Risposta
Limitazione (Art. 18)	Disattivazione account e restrizione moduli disponibili tramite pannello admin; accesso ai dati agente revocabile immediatamente su richiesta	Immediatamente su richiesta

5.4 — Politica di Conservazione

- ✓ **Dati operativi:** conservati per la durata del contratto più 12 mesi dalla cessazione (adempimento obblighi fiscali)
- ✓ **Log di sistema e applicativi:** conservazione rolling 90 giorni con rotazione automatica basata sulla dimensione
- ✓ **Cancellazione post-contrattuale:** tutti i dati personali relativi agli agenti vengono cancellati entro 60 giorni dalla cessazione del contratto; un'esportazione strutturata è disponibile prima della cancellazione in conformità all'Art. 20 GDPR
- ✓ **Monitoraggio automatico della conservazione:** scansione settimanale che identifica i clienti inattivi da oltre 24 mesi; l'agente responsabile viene notificato per revisione (nessuna cancellazione automatica — la cancellazione rimane un atto umano deliberato)

5.5 — Accordo per il Trattamento dei Dati

Un Accordo per il Trattamento dei Dati (DPA ex Art. 28 GDPR) pienamente conforme al Regolamento — comprensivo di tutte le clausole obbligatorie (oggetto, durata, natura e finalità del trattamento, categorie di dati, obblighi e diritti del Titolare del Trattamento) — sarà formalmente sottoscritto prima dell'avvio del sistema. Il DPA sarà firmato contestualmente al contratto commerciale come condizione preliminare all'attivazione del trattamento.

6. Conformità NIS2

La Direttiva (UE) 2022/2555 (NIS2), recepita in Italia con D.Lgs. 138/2024, impone ai fornitori di servizi digitali l'adozione di misure di sicurezza tecniche e organizzative adeguate. Di seguito viene effettuata la mappatura dei controlli implementati da Formicanera rispetto ai requisiti dell'Art. 21 NIS2.

Requisito Art. 21 NIS2	Implementazione Formicanera
Politiche per l'analisi del rischio e la sicurezza dei sistemi informativi	Misure di sicurezza documentate nel presente whitepaper e nella Dichiarazione di Conformità Tecnica n. 2026-001. Screening DPIA (Valutazione d'Impatto sulla Protezione dei Dati) completato. Il modello di minaccia copre autenticazione, dati in transito, dati a riposo e i confini di interazione con l'ERP.
Gestione degli incidenti	Procedura formale di risposta agli incidenti con classificazione della gravità P1/P2/P3. Notifica al Titolare del Trattamento entro 24 ore dagli incidenti P1. Notifica all'autorità di controllo (Garante per la Protezione dei Dati Personali / BSI) entro 72 ore ai sensi dell'Art. 33 GDPR. Alert di sicurezza automatici per login falliti, circuit breaker e superamento rate limit.
Continuità operativa e gestione delle crisi	Backup automatici giornalieri (notturni, ore 02:00 CET). RPO < 24 ore. RTO 30–60 minuti (ripristino database + rideploy da GitHub). Verifica dei backup registrata ad ogni esecuzione. Procedura di recupero completa documentata.
Sicurezza della catena di approvvigionamento	Hetzner Online GmbH (certificata ISO 27001, DPA firmato) come fornitore di infrastruttura principale. FedEx International (Clausole Contrattuali Standard, conforme UE) esclusivamente per l'integrazione del tracking delle spedizioni. Registro completo dei sub-responsabili del trattamento mantenuto e disponibile per audit.
Sicurezza nell'acquisizione, nello sviluppo e nella manutenzione	<code>npm audit --audit-level=critical</code> eseguito ad ogni push CI/CD — le vulnerabilità critiche bloccano il deployment. Tutte le query database sono parametrizzate (nessun rischio SQL injection). Validazione degli input tramite Zod su tutte le route API critiche per la sicurezza. Dipendenze esaminate prima dell'inclusione.
Politiche per la valutazione dell'efficacia delle misure di sicurezza	L'audit log immutabile garantisce visibilità operativa continua. Penetration test pianificato in conformità all'accordo SLA con Komet Italia prima del rollout completo sulla rete. Revisione della sicurezza integrata nel workflow di deployment.
Crittografia e cifratura	AES-256-GCM a riposo per tutte le credenziali sensibili. TLS 1.2+ in transito con applicazione HSTS. PBKDF2-HMAC-SHA256 per la derivazione delle chiavi. bcrypt per l'hashing delle password. Nessun algoritmo deprecato in uso.
Sicurezza delle risorse umane, controllo degli accessi	RBAC con quattro ruoli (admin/office/agent/dealer) + restrizioni per modulo per utente. MFA (TOTP) disponibile per tutti i ruoli. Audit log di tutte le operazioni di gestione utenti. Disattivazione account immediata su richiesta.
Utilizzo dell'autenticazione a più fattori	MFA TOTP (RFC 6238) implementato per tutti gli accessi al sistema. Codici di recupero di riserva forniti (con hash bcrypt). Meccanismo di device trust per ridurre l'attrito mantenendo il livello di sicurezza.

Nota sull'applicabilità: In qualità di Responsabile del Trattamento ai sensi dell'Art. 28 GDPR a supporto delle attività operative di un agente commerciale, Formicanera si impegna a mantenere misure di sicurezza proporzionate al profilo di rischio dei dati trattati. I controlli documentati sopra superano i

requisiti di base per un sistema di questa scala e sensibilità dei dati, riflettendo un impegno architettonico deliberato alla security-by-design piuttosto che alla compliance-by-checklist.

7. Backup e Continuità Operativa

La disponibilità e la recuperabilità dei dati sono trattate come proprietà di sicurezza, non come mere convenienze operative. L'architettura di backup è progettata per una resilienza verificabile e residente nell'UE.

Frequenza dei Backup

Backup automatico notturno eseguito alle 02:00 CET tramite cron job sul VPS di produzione. Ogni esecuzione di backup è registrata e verificabile nei log del container.

Processo di Backup

pg_dump → compressione gzip → upload cifrato su Hetzner Object Storage. Region: fsn1 (Francoforte, Germania). Lo storage rimane in ogni momento all'interno dell'UE.

Conservazione

Rotazione rolling a 30 giorni. I backup con più di 30 giorni vengono automaticamente eliminati. Gli ultimi 30 snapshot giornalieri sono sempre conservati.

RPO — Recovery Point Objective

Inferiore a 24 ore. In caso di guasto catastrofico del server, la perdita di dati è limitata all'ultimo ciclo di backup completato.

RTO — Recovery Time Objective

30–60 minuti. Ripristino del database dall'ultimo backup + nuovo deployment dell'applicazione dal repository GitHub. Il repository del codice sorgente è la fonte autoritativa di deployment.

Verifica

Il risultato di ogni esecuzione di backup è registrato. L'integrità dei backup può essere verificata in modo indipendente dal Titolare del Trattamento in qualsiasi momento su richiesta. Le prove di ripristino possono essere condotte sotto NDA in un ambiente di staging.

"Il backup non ha significato se non viene testato. Manteniamo una procedura di ripristino documentata e siamo pronti a dimostrare un recupero completo del database in un ambiente di staging nell'ambito di qualsiasi audit tecnico richiesto da Gebr. Brasseler GmbH & Co. KG."

8. Risposta agli Incidenti

Una procedura formale di risposta agli incidenti è documentata e operativa. Tutti gli incidenti sono classificati per gravità, con finestre di risposta definite e obblighi di notifica obbligatori.

P1 — CRITICO

Violazione dei dati o indisponibilità del servizio > 4 ore

Risposta: < 4 ore lavorative

Notifica al Titolare del

Trattamento: entro 24 ore

Garante per la Protezione dei Dati

Personali / BSI: entro 72 ore (Art. 33 GDPR)

Post-mortem: documentato entro 5 giorni lavorativi

P2 — ALTO

Degradazione del servizio o tentativo di accesso non autorizzato

Risposta: < 8 ore lavorative

Notifica al Titolare del

Trattamento: entro 48 ore se

sussiste rischio per i dati personali

Perimetro: fallimenti di

autenticazione, attivazione circuit breaker, pattern ERP anomali

P3 — MEDIO

Anomalie o problemi non critici del servizio

Risposta: 1 giorno lavorativo

Notifica al Titolare del

Trattamento: al successivo

aggiornamento di stato pianificato

Perimetro: ritardi di

sincronizzazione, degrado minore

delle prestazioni, problemi

funzionali non legati alla sicurezza

Alert di Sicurezza Automatici

Il sistema genera eventi `security.alert` automatici registrati nell'audit log immutabile per le seguenti condizioni:

- ✓ **Tentativi di login falliti ripetuti** — il superamento della soglia attiva la limitazione della frequenza delle richieste (rate limiting) e la generazione di alert
- ✓ **Attivazione del circuit breaker** — dopo 3 fallimenti consecutivi di operazioni ERP, tutte le interazioni con l'ERP vengono automaticamente sospese in attesa di indagine
- ✓ **Superamento rate limit** — tutti i superamenti del rate limit sugli endpoint di autenticazione vengono registrati con indirizzo IP e user agent
- ✓ **Errori di sistema ad alta frequenza** — pattern anomali di frequenza degli errori generano alert per revisione operativa
- ✓ **Rilevamento indisponibilità ERP** — gli eventi di sospensione del sistema vengono registrati con ora di inizio, durata e conferma di ripristino

9. Sub-Responsabili del Trattamento

Formicanera mantiene un registro completo e aggiornato di tutti i fornitori terzi che trattano dati personali per conto del sistema. Alla data del presente documento, l'elenco dei sub-responsabili del trattamento è il seguente.

Sub-Responsabile	Ruolo	Dati Trattati	Ubicazione	Garanzie
Hetzner Online GmbH	Hosting VPS + Object Storage (backup)	Tutti i dati di sistema (a riposo)	Falkenstein / Francoforte, Germania (UE)	Certificata ISO 27001. DPA firmato. Operazioni data center conformi al GDPR. Nessun dato lascia la Germania.
FedEx International	Integrazione tracking spedizioni	Solo numeri di tracking — nessun dato personale del cliente trasmesso	UE / USA	Clausole Contrattuali Standard (SCC) — meccanismo di trasferimento approvato dalla Commissione europea. Limitato a dati logistici di riferimento non identificativi.

Nessun servizio e-mail esterno è utilizzato per le notifiche di sicurezza. Tutti gli alert e gli eventi di sicurezza sono gestiti tramite il sistema interno di audit log. Le notifiche al Titolare del Trattamento vengono consegnate attraverso canali documentati — nessun dato personale transita attraverso fornitori di posta elettronica terzi a tale scopo.

Governance dei Sub-Responsabili del Trattamento

- ✓ Il registro completo dei sub-responsabili del trattamento è mantenuto e disponibile per audit in qualsiasi momento su richiesta
- ✓ Qualsiasi aggiunta di un nuovo sub-responsabile del trattamento sarà notificata a Komet Italia S.r.l. (in qualità di Titolare del Trattamento) con un preavviso minimo di 30 giorni, secondo i termini standard del DPA
- ✓ Ogni sub-responsabile del trattamento viene valutato rispetto ai requisiti dell'Art. 28(3) GDPR prima dell'ingaggio
- ✓ La certificazione ISO 27001 di Hetzner fornisce una baseline di sicurezza dell'infrastruttura verificata in modo indipendente

10. FAQ Tecnica per il Team IT

Di seguito vengono affrontate le domande più frequentemente sollevate dai team IT durante la revisione tecnica di sistemi basati su RPA che si interfacciano con ERP aziendali.

D1: Formicanera ha accesso a funzioni ERP amministrative o con privilegi elevati?

No. Il sistema utilizza esclusivamente le credenziali ERP standard dell'agente commerciale — le stesse credenziali assegnate da Komet Italia al Sig. Formicola per la sua ordinaria attività d'agente. Può accedere unicamente alle stesse schermate, funzioni e dati a cui l'agente può accedere manualmente. Non dispone di accesso alla configurazione ERP, non accede ai territori o ai dati di altri agenti e non dispone di funzioni amministrative all'interno dell'ERP. Permessi elevati non sono richiesti, non sono stati ottenuti e non sono tecnicamente possibili con il livello di credenziali dell'agente.

D2: Formicanera può influire sulle prestazioni o sulla stabilità dell'ERP?

Nessuna degradazione delle prestazioni ERP attribuibile al sistema è stata osservata durante l'intero periodo operativo. Il sistema è architetturalmente progettato per proteggere l'ERP: sospende automaticamente ogni interazione in caso di mancata risposta o manutenzione dell'ERP; distanzia le operazioni di recupero dati con intervalli obbligatori; riduce automaticamente la frequenza di sincronizzazione quando l'agente è inattivo. Il pattern di interazione genera un carico meno erratico di quello di un utente umano — è prevedibile, controllato e non invia mai cicli aggressivi di ritentativi. L'ERP percepisce Formicanera come una sessione utente disciplinata e ben comportata.

D3: Cosa accade ai dati in caso di cessazione del contratto?

Tutti i dati personali relativi agli agenti vengono cancellati entro 60 giorni dalla cessazione del contratto. Prima della cancellazione, un'esportazione completa e strutturata dei dati (JSON/CSV) è disponibile per il Titolare del Trattamento in conformità all'Art. 20 GDPR. L'accesso al codice sorgente, le credenziali ERP e tutti i materiali di autenticazione vengono rimossi da tutti i sistemi Formicanera. Il DPA specificherà in forma giuridicamente vincolante gli esatti obblighi di gestione dei dati post-cessazione.

D4: Il codice sorgente è verificabile tramite audit?

Sì. Un audit completo del codice sorgente può essere organizzato sotto NDA in qualsiasi momento. La pipeline CI/CD (GitHub Actions), la configurazione del deployment e l'implementazione della sicurezza sono tutti disponibili per revisione da parte del team IT di Gebr. Brasseler. Consideriamo la verificabilità del codice sorgente un'aspettativa standard per qualsiasi fornitore enterprise responsabile e accogliamo favorevolmente questo livello di scrutinio.

D5: Come vengono protette le credenziali ERP a riposo?

Le credenziali ERP degli agenti sono cifrate con AES-256-GCM con un IV casuale generato per ogni operazione di cifratura e un tag di autenticazione per il rilevamento delle manomissioni. Il materiale crittografico (IV, tag di autenticazione, testo cifrato) è serializzato separatamente e memorizzato nel database. La chiave di cifratura è derivata tramite PBKDF2-HMAC-SHA256 da una variabile d'ambiente (ENCRYPTION_KEY) che esiste esclusivamente nell'ambiente del server di produzione — non è mai presente nel codice sorgente, mai nel repository, mai nei log e mai trasmessa in alcuna risposta API. Le credenziali vengono decifrate on-demand unicamente in memoria, per la durata della sessione ERP.

D6: Formicanera genera o modifica fatture?

No. Il sistema Formicanera non genera fatture e non applica alcun calcolo finanziario ai dati fattura. Si tratta di un principio architetturale fondamentale coerente con il contratto di agenzia, in base al quale le fatture sono emesse esclusivamente da Komet Italia S.r.l. (in qualità di Preponente), non dall'agente. Tutte le fatture visualizzate nell'applicazione provengono esclusivamente dall'ERP Komet — vengono scaricate come PDF ufficiali esportati dall'ERP attraverso la sessione autenticata dell'agente e visualizzate in sola lettura, senza possibilità di modifica.

D7: Come viene monitorato il sistema per gli eventi di sicurezza?

Il sistema mantiene un audit log immutabile e append-only (PostgreSQL, con revoca dell'accesso in scrittura per le operazioni UPDATE e DELETE a livello applicativo). Tutti gli eventi di autenticazione, le operazioni sui dati, le azioni GDPR e gli alert di sicurezza vengono registrati con ID attore, indirizzo IP, user agent e timestamp. La generazione automatica di alert avviene per login falliti ripetuti, attivazione del circuit breaker, superamenti del rate limit e condizioni di alta frequenza degli errori. L'audit log è ispezionabile dagli amministratori autorizzati e disponibile per audit esterno in qualsiasi momento.

11. Dichiarazione Conclusiva

Il presente documento fornisce una descrizione completa e verificabile dell'architettura di sicurezza del sistema Formicanera, delle pratiche di protezione dei dati e del posizionamento di conformità normativa alla data di maggio 2026.

"Il sistema Formicanera è stato costruito per colmare una reale lacuna operativa — consentire a un agente sul campo di svolgere le proprie attività contrattuali in modo più efficace e accurato — mantenendo piena coerenza con l'ERP Komet quale fonte autorevole della verità. La sicurezza e la protezione dei dati non sono funzionalità aggiunte a posteriori: sono **proprietà architetturali del sistema**, documentate, implementate e verificabili."

Ogni misura di sicurezza documentata in questo whitepaper è operativa in produzione. Il codice sorgente, la pipeline CI/CD, gli audit log e le procedure di backup sono tutti disponibili per verifica indipendente sotto NDA. Non chiediamo fiducia sulla base di dichiarazioni — la offriamo sulla base delle evidenze.

Restiamo pienamente disponibili per un confronto tecnico, una dimostrazione dal vivo del sistema, una revisione del codice sorgente sotto NDA o qualsiasi documentazione aggiuntiva richiesta dai team IT e Legale/Compliance di Gebr. Brasseler GmbH & Co. KG.

Preparato e sottoscritto da:

Francesco Formicola

Developer — Formicanera Agent Management System

Per conto di: Formicola Biagio, Agente Commerciale — Komet Italia S.r.l., Cluster 83

Napoli, Italia — Maggio 2026

Contatti: francesco.formicola@live.it · formicanera.com



Formicanera

Agent Management System — Whitepaper Sicurezza e
Conformità

Whitepaper Sicurezza e Conformità — Versione 2.0 — Maggio
2026

RISERVATO — Ad esclusivo uso di Gebr. Brasseler GmbH & Co.
KG

Preparato da Francesco Formicola · formicanera.com